İç(Internal) ve Dış(External) Siber Tehditler Ve Önlemleri

Hazırlayan: RaiDeiNz

7 Mart 2021

RAPORUN ÖZETİ

Bu raporun hazırlanma amacı esasen, iç(dahili) ve dış(harici) tehditlerin neler olduğunu anlatmaktır. Fakat bilişim dünyası sürekli olarak geliştiğinden, konuyla alakalı genel bir farkındalık kazandırmak amacıyla, sektördeki yeniliklere karşı uygun adaptasyonun sağlanması; bilgi/veri(data) güvenliği yönetimi temel kavramlarının ve bilgi güvenliği standartlarının okuyucuya kazandırılması hedeflenerek hazırlanmıştır. Veriyi koruma prensiplerinin anlatımı ile başlayıp, iç ve dış tehditlerin ne olduğu, çeşitleri ve önlemlerinin açıklanması ile sonlanmaktadır.

İÇİNDEKİLER:

RAPORUN ÖZETİ **1**

GİRİŞ **4**

1-1. Karmaşıklaşan Bilişim ve Değişen Tehdit Kavramı 5

1-2. Bilgi Güvenliği Standartları / Çerçeveleri 5

1-2-1. ISO/IEC 27000 Ailesi 5

1-2-2. COBIT (ISACA) 5

1-2-3. PCI-DSS 6

1-2-4. ITIL v3 6

1-2-5. SoX, NIST, HIPAA 6

1-2-6. CMMI, PMBOK, PRINCE, COSO 6

1-3. Bilgi Güvenliği Yönetimi Temel Kavramları 6

1-3-1. Varlık 6

1-3-2. Zafiyet 6

1-3-3. Tehdit 6

1-3-4. Risk 6

1-3-5. Olasılık 6

1-3-6. Etki 7

DAHİLİ TEHDİTLER **7**

2-1. Giriş 7
2-2. Tanım 7
2-3. Dahili Tehditler 7
2-4. Dahili Tehditlerden Korunma Yöntemleri 8
2-5. Çalışanlara Verilebilecek Eğitim Konuları 8
2-5-1. Telefon Dolandırıcılığı 9
2-5-2. VPN Güvenliği 9
2-5-3. Sosyal Medya Güvenliği 9
2-5-4. Kişisel Donanım Güvenliği 9
2-5-6. Parola Güvenliği 9
2-5.7 Oltalama Saldırısı ve Kimlik Hırsızlığı 10
2-5-8 E-posta Dolandırıcılığı 11
2-5-9 SMS Oltalama Saldırısı / Smishing 11

HARİCİ TEHDİTLER 12
3-1. Giriş 12
3-2. Tanım 12
3-3. Harici Tehditler 12
3-3-1. DDoS 12
3-3-2. Session Hijacking 13
3-3-3. Drive-by Attack 13
3-3-4. Password Attack 13
a. Phishing 13
b. Man-in-The-Middle Attack 14
c. Brute Force Attack 14
d. Dictionary attack 14
e. Credential stuffing 14
f. Keyloggers 14
3-3-5. Spear Phishing 15
3-3-6. Ransomware 15
3-3-7. Malware 15
3-3-8. Malvertising 15
3-3-9. APT 15
3-4. Harici Tehditlerden Korunma Yöntemleri 16

İÇ VE DIŞ TEHDİTLERE HEDEF OLABİLECEK KİŞİLER 16
4-1. Kişiler 17
4-2. Kurumlar ve Şirketler 17
4-3. Ülkeler 17
4-4. Birlikler ve Gruplar 17
4-5. Dünya ve Ötesi 17

KAYNAKÇA 17

1. GİRİŞ

Bu rapora başlamadan önce, olayların kronolojik gelişimine biraz daha geriden bakmak gerekiyor. Soru : Bilişim teknolojilerindeki standart ve çerçeve modelleri neden geliştirilir ?

Mesela çok ufak değinerek, TCP / IP ve OSI modellerinin başlangıçta neden oluşturulduğunu anlayalım. İlk başlarda standartlaştırma diye bir kavram yoktu. Haliyle üreticiler kendi metodolojilerini takip ettiler ve sonuç olarak farklı üreticiler tarafından yapılan farklı sistemler, ağ oluşturma söz konusu olduğunda tamamen uyumsuzdu. Bu sebeple Amerikan Savunma Bakanlığı tarafından TCP / IP modeli 1982 yılında, bir standart sağlamak için tanıtıldı. Burada amaç, tutarsızlık sorunlarının çözülmesini sağlamak ve bir ortak ağ oluşturmaktı.

1-1. Karmaşıklaşan Bilişim ve Değişen Tehdit Kavramı

Kurumlar için bilişim altyapılarının ve hizmetlerin karmaşıklığı gün geçtikçe daha da artmakta; *Gizlilik, Bütünlük, Erişilebilirlik, Erişim Doğrulama, Şifreleme, Yedeklilik* vb. temel değerler sürekli değişmektedir.

Gelişen bilişim dünyası, çeşitlenen hizmetler ve teknolojik yenilikler, tehdit kavramlarını ve algılarını da ciddi anlamda değiştirmektedir.

Bu değişimin hızına son kullanıcı olarak bizler bile yetişemezken, tehditlerin sabit kalmasını bekleyemeyiz. Bu sebeple bilişim dünyasında herkesin, kullandığı ürün ve dijital yenilikler hakkında fikir sahibi olması gerekmektedir.

1-2. Bilgi Güvenliği Standartları / Çerçeveleri

Değişmekte olan bilişim dünyasıyla beraber, mevcutta var olan ve yenilerinin de çıkacağı siber tehditlerin yanında, karşılaşılacak riskleri de önlemek adına bazı ülkeler ve şirketler, birtakım standartlar oluşturmuştur.

1-2-1. ISO/IEC 27000 Ailesi

Bilgi varlıklarını güvende tutmak adına; her türden kuruluşun finansal bilgiler, fikri mülkiyet, çalışan bilgileri veya üçüncü şahıslar tarafından emanet edilen bilgiler gibi varlıkların güvenliğini yönetmesini sağlar.

1-2-2. COBIT (ISACA)

COBIT yöneticilere, denetçilere ve Bilgi Teknolojileri kullanıcılarına iş hedeflerinin bilgi işlem hedeflerine dönüşümünü, bu hedeflere ulaşmak için gerekli kaynakları ve gerçekleştirilen süreçleri bir araya getirirken, aynı zamanda bilgi teknolojileri alt yapılarını da etkin kullanmayı sağlar.

1-2-3. PCI-DSS

Kredi kartları ve akıllı kart kullanan kuruluşlar için bir bilgi güvenliği standardıdır.

1-2-4. ITIL v3

Bilgi teknolojileri hizmetlerini, işletmenin ihtiyaçları ile uyumlu hale getirmeye odaklanan bilgi teknolojisi hizmet yönetimi (ITSM) için ayrıntılı bir uygulama çerçevesidir.

1-2-5. SoX, NIST, HIPAA

Şirket ve Sektörlere Çözümler Üreten Standartlardır.

1-2-6. CMMI, PMBOK, PRINCE, COSO

Yazılım, Proje vb Development(Geliştirici) Araçlarının Standartları.

1-3. Bilgi Güvenliği Yönetimi Temel Kavramları

Varlıkların ve tehditlerin iyi analizi, riskleri yönetimimizdeki temel yapı taşını oluşturmaktadır.

Bilgi güvenliği adına oluşturulan standart ve çerçevelerin, oluşumlarında esas aldığı bazı kavramlar vardır. Bu kavramların metodolojisini kendimiz için düzgün bir şekilde yönetebilirsek, kendimizi nispeten bu tehditlerden korumuş oluruz. Bu kavramlar :

1-3-1. Varlık

Sahip olunan ve bizim için değer taşıyan şey.

1-3-2. Zafiyet

Olası bir tehdidin oluşmasında kullanılabilen açıklık, zayıflık.

1-3-3. Tehdit

Sonucunda zarar görülebilecek -olası- herhangi bir eylem.

1-3-4. Risk

Zafiyetten kaynaklanan tehdidin oluşması durumu.

1-3-5. Olasılık

Riskin olma, gerçekleşme ihtimali.

1-3-6. Etki

Risk oluştuğunda yaratacağı sonuç.

2. DAHİLİ TEHDİTLER

2-1. Giriş

2017'de yapılan bir ankete göre, şirket çalışanlarının %72'si, şirket bilgilerini paylaşma eğiliminde. Ve bu kişilerin %65'i, korunması gereken verilerin, kendi sorumlulukları dahilinde olduğunun bilincinde oldukları halde, bu verileri paylaşmak istiyor…

2-2. Tanım

Sektörün, enstitünün veya devlet firmalarının içinden kaynaklanan ve bir çalışanın terfisindeki memnuniyetsizlik veya aniden işten çıkarılması nedeniyle istismara neden olan bir tehdit, dahili bir Siber Tehdit olarak bilinir. Bu tür tehdit, çalışanın çalıştığı yere yönelik zihinsel düşünceleriyle ilgili şikayetlerinden sonradır.

Ayrıca personelin, işyerinin içeriğine erişmesine izin verildiğinden, bu; kişinin zihninde olumsuz düşünceler doğduğunda büyük bir veri ihlali olabileceği anlamına gelir.

Büyük veya orta ölçekli bir işletmede herkesin zihniyetini okumak ve ona göre çalışmak mümkün değildir. Bazen bir çalışanın kendi şirketini isteyerek sabote edeceğine inanmak zor olabilir ve bazen kasıtlı olarak gerçekleşse de çoğu zaman tamamen tesadüfi olur. Başlıca dahili siber tehditler şöyledir :

2-3. Dahili Tehditler

- **İşten çıkarıldıktan veya izin verildikten sonra çalışan tarafından verilerin sızdırılması.**
- **Finansal kazanç için şirket verilerinin satılması.**

- Ticari sırların çalınması.

- Evden çalışanların vishing (şirket çalışanı kimliği ile aramak) dolandırıcılığı ile kandırılması.
- Rekabet avantajı sağlamak için şirket verilerini yeni bir işverene götüren çalışan.
- Çalışanın, müşteri verilerini sızdırması.
- Rüşvet teklif edilerek bir çalışanın ayartılması.
- Yanlışlıkla yanlış kişiye e-posta gönderilmesi.
- Erişim ayrıcalıklarını yanlışlıkla yanlış yapılandıran çalışanın sisteminin savunmasız olması.
- Erişim yetkileri ayarlanırken, yanlış çalışana yüksek erişim izni verilmesi.
- Şirket verilerinin, kişisel bir e-posta hesabına gönderilmesi.
- Sahibi olmadığı bir harici belleğin, herhangi bir amaçla şirket donanımına takılması vb.

2-4. Dahili Tehditlerden Korunma Yöntemleri

- Temel veri kaynaklarınızdaki dosyaları, e-postaları ve etkinliği izleyin(Monitoring).
- Hassas dosyalarınızın/verilerinizin nerede bulunması gerektiğini belirleyin.
- Bu verilere kimin erişimi olduğunu ve bu verilere kimin erişimi olması gerektiğini belirleyin.
- Eski çalışanlarınızın veri erişim izinlerini/hesaplarını kaldırın.
- Yeni çalışanların şifrelerini, belli bir algoritma olmadan rastgele oluşturun.
- Her türlü yazılımınızı gözden geçirin, güncelleyin.
- Şirketiniz için risk analizi doğrultusunda, güvenlik politikası yayınlayın.
- Çalışanlarınızı bir sosyal topluluk haline getirip kaynaşmalarını sağlayın ve eğitim verin.

2-5. Çalışanlara Verilebilecek Eğitim Konuları

Bilişim dünyasındaki gelişmeler, tehditlerin de sürekli yenilerinin oluşmasına sebep olmaktadır. Herhangi bir konu hakkında farkındalık kazanmak, sizi sadece o konudaki tehditlerden koruyacaktır. Bu nedenle kişilerin, sürekli olarak kendilerini geliştirmeleri gerekmektedir. Bu detay, tüm raporun, kişiye farkındalık kazandırmak esasına dayanarak hazırlanmasından dolayı verilmiştir.

Bir şirket çalışanın edinmesi gereken bilgiler şunlardır :

2-5-1. Telefon Dolandırıcılığı

Günümüzde, "Caller ID Spoofing" gibi metotlarla telefon numaraları bir başka numara gibi gösterilebiliyor. Arayan kişi şirketinizin numarasından arıyor gibi de gözükebilir. Veya bu numaradan mesaj da atabilir. Bu tür vishing tuzaklarından korunmak için, hassas verilerinizi doğrudan paylaşmayın.

2-5-2. VPN Güvenliği

VPN(tünel bağlantı) esasen şirket içi güvenli ve şifrelenmiş veri iletimini sağlamak ayrıca şirket ağlarını birbirine bağlamak için geliştirilmiş bir teknolojidir. Pandemi ile birlikte birçok kişi, kurumuna vpn ile bağlanmak zorunda kalmıştır. Cihazınızda bir VPN oluşturduğunuzda, ek kimlik doğrulama seçeneklerini kullanmanız gerekir. Ayrıca yerel ağınızda bir VPN bağlantısı, tek bir cihazda kullanılmalıdır.

2-5-3. Sosyal Medya Güvenliği

İnterneti güvenli bir şekilde kullanıyor olsanız da, arkadaşlarınız sizin kadar bilinçli kullanmıyor olabilir. Bu sebeple arkadaşlarınızdan da geliyor olsa, sosyal medyada paylaşılan her bağlantıya özellikle dikkat etmek gerekir.

2-5-4. Kişisel Donanım Güvenliği

Her ne kadar cihazlarımıza şifre koymuş olsak da, zaman zaman oturumu açık bırakıp bilgisayardan kalktığımız; bir restoranda masada arkadaşımız var diye telefonu masaya bırakıp lavaboya kalktığımız oluyor. Biz yapmasak bile bu, sık sık rastlanılan bir davranış. Oysa sd-kart ile bir telefon kolaylıkla ele geçirilebilir. Bir bilgisayara 2 dakikada kalıcı arka kapı oluşturulabilir.

2-5-6. Parola Güvenliği

Enigma, ilkel bir şifreleme cihazıdır. Ve yine ilkel bir şifre kırıcı olarak üretilen Colossus bilgisayarı da, 2. dünya savaşının gidişatını değiştirmiştir.

En sık rastlanılan durum, şifrelerin güvensiz ve basit oluşturulmasıdır. Bir şifre oluştururken, bunun karmaşık yapıda olduğundan emin olmalıyız. İnsanların en sık düştüğü hata, karmaşık şifre oluşturulmasının gerekli olduğu uygulamalarda; büyük harfli karakterin genelde ilk harf oluşu, sayının 123 ve özel karakterin de enter tuşuna yakınlığından dolayı nokta oluşudur. Bu tür şifreler, diğerleri kadar basit olmasa da, tahmin etmesi kolay şifrelerdir. Şifre oluştururken, etrafınızdaki objelerden ilham alınmamalıdır. Ayrıca "Parola Güvenliği" konusunda bilinmesi gereken diğer hususlar da şu şekildedir :

- **Parolaların Korunması**
  Pin ve parolaların, herhangi bir mecburiyet durumunda dahi paylaşılmaması gerekir. Market ürünlerini poşetlerken, kart şifresini girmesi için marketçiye söyleyen birine denk gelmek oldukça mümkündür.

- **Daha Önce Oluşturulan Bir Parolaların Yeniden Kullanılmaması**
  Geçen hafta yaşanan kitapyurdu olayında da gözlemlendiği üzere kullanıcılar, hem basit şifreler oluşturmuş, hem de aynı kullanıcı adı ve şifreyi farklı sistemlere kaydolurken de kullanmışlar. Aralarında eski milletvekilinin de olduğu söyleniyor. Şifresinin aynı olduğu durumda, fatih.ciftci@tbmm.gov.tr adresiyle, sisteme erişebilecekleri ve devlet sırlarını çalabilecekleri ihtimali, korkutucu bir gerçektir.

- **Parolaların En Azından Orta Seviyeli Güvenlik Düzeyinde Olması**
  Şifreler oluşturulurken, izin verilen her tür ascii tablosu karakterini kullanmak, güzel bir yaklaşım olacaktır. Şifreler oluşturulurken en azından 12 karakterden başlamasına, içerisinde sayı veya rakam, büyük küçük rastgele harfler ve özel karakterler kullanılmalıdır. Bir şifre en azından bu şekilde olmalıdır: **Bu_53kiLd3_0lm4liDIR!**

2-5.7 Oltalama Saldırısı ve Kimlik Hırsızlığı

Oltalama saldırıları son derece popüler bir çevrimiçi saldırı metodudur. Kişilere son derece gerçekçi e-postalar atarak, kurum ve kuruluşları taklit ederek, duruma göre biraz acele hareket etmenizi teşvik eden ya da korkutucu bir içeriğe sahip olup size endişe verecek türde hazırlanırlar. Tabii ki bu şekilde olmak zorunda da değil.

Bir phishing(oltalama saldırısı) ya da spear phishing(hedeflenmiş oltalama saldırısı) kurbanı olmamak için yapılabilecek en basit yöntemler, gönderen adresin doğruluğunu onaylamak için mailin yanında bulunan ayrıntı okuna tıklamaktır. Bunun yanı sıra, size mail

atan kurumun/kuruluşun, subdomain'den (alt alan adı ör: www) top level domain'e kadar (üst alan adı ör: .com) incelenerek, adreslerin doğruluğunu onaylamak da bir seçenektir. Mesela : **myaccount.google.com--boylebirsiteyokt.ru/hesap-kurtarma**

Genellikle uzun linklerin baş tarafları oldukça güvenilir gözüküp, farklı parametrelerle sizi kendi sunucularına yönlendirildiğini gizlerler. Ya da url dönüşümleriyle beraber sizi kandırmaya çalışırlar. 'Url decoder' gibi url'lerin karmaşıklığını çözümleyen araçlar kullanılabilir. Her domain katmanının aslında bir dosya ismine eşdeğer olduğu bilincine sahip olursak, dosya ismi oluştururken özel karakterleri atlatarak oluşturulabilecek sahte sitelerin de farkındalığını kazanmış oluruz. Mesela aşağıdaki iki url birebir aynı gözükseler de, dosya ismi bakımından birbirinden farklıdır :
https://github.com/RaiDeiNz/awesome-iocs
https://github.com/RaiDeiNz/awesome‑iocs

İkinci url incelendiğinde(mesela url encoding yaparak kontrol edilebilir), awesome isminden sonra gelen kısa çizgi "-" yerine, **%E2%80%90** ifadesinin kullanıldığı, dikkat edilmesi gereken kısımdır. Bu tür atlatmalar yapılabilmektedir.

2-5-8 E-posta Dolandırıcılığı

Yine phishing saldırısına benzer bir metodu olan e-posta dolandırıcılığı ile siber korsanlar size, sahip olmadıkları halde, farklı bir domain adresinden mail gönderebilirler. Şüpheli bir içeriğe sahip, sizi kuşkulandıran maillerde; bu tür saldırılara yakalanmamak için, e-posta üst bilgilerini kontrol etmek gerekir. Bu yöntem ile e-postanın çıktığı kaynaktan, size ulaşana kadar geçirdiği her tür işlem, ayrıntılarıyla gözükmektedir. Bunun için kullandığınız e-posta servisinin, üst bilgi gösterim araçları kontrol edilmelidir. Outlook'da mail kutunuzdan bu özelliklere erişebilirken, gmail için farklı bir servis kullanmanız gerekmektedir.

2-5-9 SMS Oltalama Saldırısı / Smishing

Teknolojinin ve bilişim sektörünün sürekli geliştiğinden/değiştiğinden, kronolojik yapı ile konuyu anlatırken bahsetmiştik. Sms ile oltalama saldırısı da, şirketlerin ve insanların, phishing gibi e-posta oltalama saldırılarına daha duyarlı olmasının ardından, siber suçlular tarafından geliştirilmiş, farklı bir metodoloji ile hareket ettikleri saldırı türüdür.

Caller ID Spoofing tekniğinden bahsetmiştik. Bu, sizin numaranızı bir başkasının numarası gibi gösteren bir araç. Bu şekilde kişi, rehberinizdeki bir numarayı taklit ederek, rehbere kayıtlı ismi ile size mesaj atabilir. Ya da bir kurumun resmi numarasını taklit ederek, kurum gibi davranabilir. Sonuçta yapılan olay aynıdır. Size bir başkası gibi gözükerek, çeşitli bağlantılar gönderip, bunlara tıklamanızı ve bir işlem yapmanızı isterler. Bilgisayarda olduğu

gibi bazı url'ler, tıklandığı anda telefonunuza bir malware(zararlı yazılım) bulaştırabilir. Veya kurumun gerçek sitesi gibi gözüken sahte bir bağlantıyla, kimlik bilgilerinizi, ya da şirket bilgilerinizi çalabilir.

3. HARİCİ TEHDİTLER

3-1. Giriş

'Cloud survey' *sonuçlarına göre çoğu durumda, temel iş içeriğini(data vb) çalmak için harici siber suçlarının işlendiği görülmüştür. Truva atı, solucanlar, kimlik avı, zararlı yazılım vb. saldırılar, hedef bilgisayara erişim sağlamak için oluşturulur. Anonymous gibi birkaç siber suç grubu, devlet kurumlarına ve kuruluşlarına saldırılar gerçekleştiriyor. Bu tür bir grup suçunun perspektifi, ahlaki bir ders vermek veya hedef firmadan bir tür intikam almaktır. Şirketinizin veya sektörünüzün, bu grupların tehdidi altında olmaması mümkün olabilir; ancak yine de bireysel bilgisayar korsanlarının hedefi altında. Bazı durumlarda, harici saldırıların ana hedefi müşterinin kayıtlarını ifşa etmek veya çalmaktır. Bunun nedeni bu faaliyetin sonucunda, Darkweb'de belirli bir fiyata, kişisel bilgilerin satılıyor olmasıdır.*

3-2. Tanım

Kötü amaçlı yazılım, kimlik avı, DDoS saldırıları, fidye yazılımı; bunlar, bilgisayar korsanlarının sitenize, yazılımınıza veya ağınıza erişmek için harici olarak kullandıkları saldırı ve yöntemlerden yalnızca birkaçıdır. İyi bir siber güvenlik firmasının repertuarının bir parçası, bu sorunların her biriyle başa çıkma ve hangi biçimde olursa olsun harici siber güvenlik risklerini önleme becerisidir.Erişim sağlandıktan sonra, bu siber suçlular bazen aylarca fark edilmeden sistem içinde kalarak bilgi çıkarırlar. Çoğu asla bulunmaz ve daha sonraki bir tarihe kadar harekete geçmezler.

Bir kurumun iç saldırılardan ziyade, dış saldırı ile karşı karşıya kalacağı için, bilgisayar korsanlarını dışarıda tutmak adına çevreyi(Network Perimeter) güçlendirmek gerekmektedir.

3-3. Harici Tehditler

3-3-1. DDoS

Dağıtılmış Ağ Saldırıları veya Hizmet Reddi (**Distributed Denial of Service**) saldırıları adıyla bilinen harici bir tehdittir. Bu tür saldırılar, bir şirketin web hizmetini sağlayan altyapı gibi, herhangi bir ağ kaynağı için geçerli olan belirli kapasite sınırlarından faydalanır. DDoS yöntemi ile saldıran bir siber suçlu, hedefindeki web kaynağına birden çok istek göndererek web sitesinin çok sayıda isteği işlemeye çalışması ile, kapasitesinin aşılmasını ve doğru şekilde çalışmamasını amaçlar. DDoS saldırıları, genellikle botnetler kullanılarak yürütülür.

Botnet : Ip adresleri ele geçirilmiş donanımlar(Zombi makineler).

3-3-2. Session Hijacking

Html, bir web sitesi oluşturmak için standart bir metin işaretleme dilidir. Teknoloji geliştikçe, web içerikleri de şekillenmiş, oturum gerektiren uygulamalar ve çok sekmeli sayfalar meydana gelmiştir. Bir web sitesi arayüzüne erişmek için sizden istenen kullanıcı adı ve şifresi, size yalnızca o anlık ve o sayfa için(ör : mypage.html) erişim izni vermektedir. Sayfayı yenilediğinizde bile, yeniden giriş yapmanız gerekmektedir. Bu sebeple hiper-metin transfer protokolü (HTTP), 1994 yılında cookie(çerez) kavramını çıkarttı. Çerez, herhangi bir internet sitesi tarafından bilgisayara bırakılan bir tür tanımlama dosyasıdır. Çerez dosyalarında oturum bilgileri(session ids) ve benzeri veriler saklanır. Bu sayede sayfa yenileme veya site altında farklı sekmelere erişme esnasında, yeniden giriş (log-in) yapmak gerekmemektedir.

Fakat bu cookieler, varsayılanda belirli bir başlığa ve kuyruğa sahiptir ve sizin oturum bilginiz, bu şifrelenmiş verinin ortalarında yer alır. Farklı kullanıcılar oluşturarak verilerdeki değişimi gözlemleyen bir siber suçlu, değişime uğrayan kısımdaki şifreleme tersine işleyerek, herhangi bir kullanıcı gibi hareket edebilir, sisteme giriş yapabilir. Buna varsayılan olarak bırakılan, ‘admin’ kimliği de dahil.

3-3-3. Drive-by Attack

Siber suçlular, güvenli olmayan web sitelerini arayıp bu sayfalardaki http (ör : 404 sayfası) veya php koduna kötü amaçlı bir komut dosyası yerleştirir. Bu komut dosyası, kötü amaçlı yazılımı doğrudan siteyi ziyaret eden birinin bilgisayarına yükleyebilir veya kurbanı, siber suçlular tarafından kontrol edilen bir siteye yeniden yönlendiren bir IFRAME üzerindeki formu alabilir.

Bu tür saldırılara 'arabadan indirmeler' adı verilir çünkü mağdurun herhangi bir işlem yapması gerekmez. Sadece siteyi ziyaret etmesi yeterlidir.

3-3-4. Password Attack

Bu saldırı vektörü, altında diğer saldırı vektörlerini barındıran bir harici tehdit türüdür.

Bu saldırıları şöyle listeleyebiliriz :

- **a. Phishing**

Dahili tehditlerde de bahsettiğimiz gibi ***oltalama saldırısı/kimlik avı***, güvenilir bir taraf gibi davranan bir bilgisayar korsanının kişisel bilgilerinizi gönüllü olarak ifşa etmenizi umarak size sahte bir e-posta göndermesidir. Bazen sizi sahte 'şifrenizi sıfırlama' ekranlarına yönlendirirler; bazen de, tıkladığınız bağlantılar cihazınıza keylogger gibi kötü amaçlı yazılımları bulaştırır.

- **b. Man-in-The-Middle Attack**

Ortadaki adam (MitM) saldırıları, bir bilgisayar korsanının veya güvenliği ihlal edilmiş bir sistemin, iki kişi veya sistem arasına girdiği ve parolalar dahil olmak üzere birbirlerine aktardıkları verilerin loglandığı saldırıdır. Saldırgan, araya kendi web sunucusunu koyarak tüm iletişimi kaydedebileceği gibi, anlık olarak da gözlemleyebilir. Kurban bir sisteme giriş yaparken kullanıcı adı ve şifresini girip log-in butonuna bastığında, bu istek(post request) önce saldırgana gitmek suretiyle, uzak sunucuya iletilir. Bu esnada saldırgan, kurbanın kimlik(credential) bilgilerini çalmış olur.

- **c. Brute Force Attack**

Brute Force saldırı türü, bir combolist kullanılarak, kurbanın şifresini bulmak amacıyla, çok sayıda şifre ve kullanıcı adı kombinasyonunun denenmesidir. Raporu hazırlarken çalıştığım kaynakta ifade edilen örneği aynen kullanmak istiyorum. Bir parola, bir kapıyı açmak için kullanılan anahtar ile tasvir edilecek olursa, kaba kuvvet saldırısı bir koçbaşı kullanmaktır. Bir bilgisayar korsanı 22 saniyede 2,18 trilyon şifre / kullanıcı adı kombinasyonunu deneyebilir.

- **d. Dictionary attack**

Dictionary yani sözlük saldırısı, nispeten kaba kuvvet saldırısına benzese de, burada amaç daha kesin sonuçlar elde etmektir. Sosyal medya mecralarında -mesela instagramda paylaştığınız evcil hayvanınızın resminde, resmin açıklama kısmına hayvanın adını yazmanız gibi- sizin hakkınızda bilgi toplayan bir saldırgan, bu bilgilerle doğum tarihi, evcil hayvan adı, doğduğunuz şehir ve plakası gibi bilgilerden bir liste hazırlar ve neredeyse

kesin sonuçlarla amacına ulaşır.

- ### e. Credential stuffing

Kimlik avı saldırıları, kitapyurdu vakasında yaşandığı gibi, daha önceden sızdırılmış bilgilerin aynılarını farklı kaynaklarda deneyerek yapılır. Şayet aynı veya çok yakın şifreler kullanıyorsanız, bu saldırıların kurbanı olabilirsiniz.

- ### f. Keyloggers

Keylogger, klavyede basılan her tuşu kaydeden kötü amaçlı bir yazılımdır. Bu kötü amaçlı yazılımın bilgisayarınıza bulaşmış olması gerekmez. XSS açıkları bulunan web sitelerinde, bir log adresinde yönlendirilmiş olarak da çalışabilmektedir. Harici siber saldırıda bulunan kişi, sitedeki kullanıcıların bilgilerini ele geçirmek için, bu tür atak vektörlerinden yararlanmaktadır.

3-3-5. Spear Phishing

Hedeflenmiş oltalama saldırısı, normal oltalama(phishing) saldırısından farklı olarak, belirli bir grup ya da sektöre yönelik, dolandırıcı e-postaların gönderildiği saldırı türüdür.

3-3-6. Ransomware

Fidye yazılımı, şantaj yazılımı veya fidye virüsü olarak bahsedilen yazılımlar, ransomware olarak adlandırılan fidye yazılımlarına verilen genel bir addır. Fidye virüsleri bulaştığı bilişim sistemleri üzerindeki dosyalara erişimi engelleyerek kullanıcılardan fidye talep eden zararlı yazılımlardır.

3-3-7. Malware

Zararlı yazılım, kötü amaçlı yazılım veya malware, bilgisayar ve mobil cihazların işlevlerini bozmak, kritik bilgileri toplamak, özel bilgisayar sistemlerine erişim sağlamak ve istenmeyen reklamları göstermek amacı ile kullanılan yazılımdır.

3-3-8. Malvertising

Malvertising, yani kötü amaçlı reklam, size canlı olmasa da sosyal mühendislik uygulayan, bunu sağlamak için duygularınızdaki zafiyete saldıran zararlı yazılımlardır. Bazı web uygulamaları, her türlü reklamı kabul etmektedir. Sitelerdeki credential ve cookie

bilgilerinizden veri toplayarak size, hedefli uyarılarda bulunur. Mesela kendisini Kaspersky olarak gösteren, ve bilgisayarınıza virüs bulaştığını, sizden acele etmenizi isteyerek "Hızlı Tara" butonuna tıklamanızı isteyebilir. Bunu yaparken de http header bilgilerinizden, kullandığınız tarayıcı modeli ve sürümü ile, o sürümdeki bir zafiyetten kaynaklandığını söyleyerek, inandırıcılığını arttırabilir. En bilinen eski örnekleri, msn bildirimleridir.

3-3-9. APT

Birçok ülkede bulunan ulus siber militanları ve siber istihbarat korsanları, birtakım gruplara bölünüp organize planlar yaparak, uzun vadede kalıcılık elde etmeyi hedefledikleri saldırılarda bulunurlar. Gelişmiş kalıcı tehdit (APT) grupları; sürekli, gizli ve gelişmiş korsanlık tekniklerini kullanarak bir sisteme erişir ve burada, yıkıcı sonuçlar yaratmayı hedeflerle. Bu gruplardan bazıları mitre gibi kaynaklarda, kullandıkları taktik, teknik ve prosedürler gibi detaylarla beraber, hakkında istihbarat edinilmesi için paylaşılırlar.

3-4. Harici Tehditlerden Korunma Yöntemleri

Madde 2-5'de yer alan eğitimlerin yanı sıra, harici tehditlerden korunma yöntemi için kişi ve kurumların düzenli olarak sızma testi yaptırması gerekmektedir. Bu kurumun bir sızma testi hizmeti veren kurum olması durumunda bile, aynı hizmeti bir başka kurumdan alması önerilir.

- Bu testlerin doğrultusunda, sistemdeki zafiyetlerin tespiti yapılıp, gerekli altyapı ve sistemlerin gözden geçirilmesi ve güncellenmesi sağlanabilir.

- Bazı güvenlik önlemleri, iç tehditlerde olduğu gibi, dış tehditler için de geçerlidir. Bunlara bir diğer örnek de, harici bellek kullanımı. Yüksek saklama kapasitesine sahip flash bellekler, kimi zaman sosyal medya mecralarından yapılan takip ve tespitlerle, hedeflenen kurumdaki bir kişinin kimlik bilgileriyle hazırlanmış anahtarlık benzeri objeler eklenerek, bu flash bellekler daha inandırıcı hale getirilip, şirket yakınlarında bırakılabilir. Ransomware gibi harici tehditleri engellemek adına, bu tür saldırılara duyarlı olmak gerekmektedir.

- Şirkete/kuruma gelen bir tadilatçı, tesisatçı, yemek sepeti kuryesi gibi şahıslar, doğru kimlik tespitleri ve doğrulama yapılmadan içeri alınmamalıdır.

- Şirket, düzenli olarak veri yedeklemesi yapmalıdır.

- Şirket, sunucularını DDoS saldırılarına karşı yapılandırmalı, aynı kaynaktan gelen çok sayıda istek, belirli aralıklara bölünerek alınmalıdır. Şayet aynı istek tekrarlanıyorsa, kaynağın engellendiği bir altyapı hazırlanmalıdır.

4. İÇ VE DIŞ TEHDİTLERE HEDEF OLABİLECEK KİŞİLER

İç ve dış tehditlere hemen herkes hedeftir. Genellikle siber suçlular, daha büyük ölçekli kazanımlar için, ya da yüksek prestij için, kendilerine zorlu firma/kurum ve kuruluşları hedef almaktadır. Fakat toplumun en küçük yapı taşı olan bireyden, ülkelerin de üzerinde hemen her şey hedef olabilir. Listeleyecek olursak :

4-1. Kişiler

Herhangi bir kişi, daha büyük bir planın parçası olarak ulaşılması gerekilen bir hedef olabilir.

4-2. Kurumlar ve Şirketler

Google,Facebook, xxx.gov.*, xxx.mil.*

4-3. Ülkeler

Scada gibi sistemlerle yönetiminin sağlandığı altyapı hizmetlerini hedef alan bir siber suç grubu, bu sistemleri ele geçirerek, yönetim kontrolleri üzerinden ülkelere zarar verebilir.

4-4. Birlikler ve Gruplar

Anonymous, RedHack gibi grupların kendi aralarında birbirlerini hedef almasının yanı sıra, ırkçı bir politikaya sahip hactivist bir grup, kendinden olmayan toplulukları hedef alabilir.

4-5. Dünya ve Ötesi

Bugün Mars, kolonileştirilmesi planlanan bir gezegen. Bunun dışında düzenli olarak uzaya araç göndermekteyiz. Bunlardan en kolay akla geleni uydular. İletişim üstyapısı olarak uydular, haberleşme ve GPS sistemleri için kullanılmaktadır. Bunun dışında gözlem yapmak için yakınlaştırma bakımından gelişmiş lenslere sahip uydular, farklı tür istihbarat amaçları için birer hedef olabilmektedir.

KAYNAKÇA

Madde 1-1 1-3 arasındaki konunun işleyiş diyagramı için kaynak : karel.com

Madde 1-1 1-3 arasındaki konu için video kaynağı : Youtube

Madde 1-2-1 için kaynak : iso.org

Madde 1-2-2 için kaynak : Wikipedia

Madde 1-2-3 için kaynak : Wikipedia

Madde 1-2-4 için kaynak : Wikipedia

Madde 2-4 için kaynak : varonis.com

Madde 2-5 için kaynak : keepnetlabs.com

Madde 3-3-1 için kaynak : Kaspersky

Madde 3-3-2 için kaynak : Wikipedia

Madde 3-3-3 için kaynak : Kaspersky

Madde 3-3-4 için kaynak : onelogin.com

Madde 3-3-6 için kaynak : Wikipedia

Madde 3-3-7 için kaynak : Wikipedia

Madde 3-3-8 için kaynak : Wikipedia

Madde 3-3-9 için kaynak : Kaspersky

Genel konu kavramı için kaynak : 1. cloudcodes.com 2. ermprotect.com